

Cloud Compliance & Governance Controls

Framework Mapping & Compliance Checklist, Gap Analysis & Remediation, AWS Organizations/SCPs, Mandatory Tagging, and AWS Config Rules with Documented Enforcement Evidence

Scenario organization: Horizon Valley Medical Center (HVMC)

Capstone project: AccessGuard Health — Azure/Entra ID & AWS IAM Operations

Rubric item: Cloud Compliance & Governance Controls (Cloud Security 1)

Framework mapped: HIPAA Security Rule, crosswalked to NIST CSF 2.0 via NIST SP 800-66r2

Builds on: the Compliance Auditing Basics, Documentation & Reporting, and Legal & Ethical Implementation submissions for this same AWS IAM environment

Report date: October 6, 2026

Created by: Sabitha S Karanavar

This submission is prepared as a classroom lab exercise for the HVMC simulation used in this capstone. Framework citations are to real, current authority (HIPAA/NIST); AWS configuration states, gap findings, and enforcement evidence are illustrative/simulated against the lab's AWS IAM environment and do not describe a live production account.

Rubric Cross-Reference

Rubric Requirement	Where Addressed
Map cloud configurations to one major compliance framework (CIS Benchmarks, NIST, or HIPAA/PCI DSS), creating a compliance checklist with gap analysis and remediation plans	Section 1 — Compliance Framework Mapping & Checklist; Section 2 — Gap Analysis & Remediation Plan
Configure AWS Organizations with Service Control Policies and mandatory resource tagging	Section 3 — Governance Implementation
Implement automated compliance checking using AWS Config Rules with documented evidence of policy enforcement	Section 4 — Automated Compliance Checking & Documented Evidence

This submission reuses the same HIPAA Security Rule Technical Safeguards scope audited in the companion *HVMC_Compliance_Auditing_Basics.pdf* (Unique User Identification, Audit Controls, Login/Logout & Session Termination) and carries its two open findings — the orphaned AWS IAM account and the missing log-retention configuration — forward into this document's gap analysis, so the governance controls built here (SCPs, tagging, Config Rules) are shown closing the same gaps that audit identified, not a disconnected set of new ones.

1. Compliance Framework Mapping & Checklist

1.1 Framework Selected

Of the frameworks this rubric permits (CIS Benchmarks, NIST, or HIPAA/PCI DSS), this submission maps HVMC's AWS configuration to the **HIPAA Security Rule (45 CFR §164.312)**, the same framework already used for this AWS IAM environment's audit and legal-compliance work, and crosswalks each requirement to its corresponding **NIST CSF 2.0** subcategory using the official **NIST SP 800-66r2** HIPAA-to-CSF crosswalk. This keeps one consistent framework across the whole compliance submission set while still satisfying the rubric's NIST-mapping expectation.

1.2 Cloud Compliance Checklist

Framework Requirement	HIPAA Citation	NIST CSF 2.0	AWS Configuration	Status
Unique identification for every user	§164.312(a)(2)(i)	PR.AA-05	Individually-owned AWS IAM users/roles	MET (1 exception — see 2.1)
Audit controls / access logging	§164.312(b)	PR.PT-01, DE.AE-03	CloudTrail, VPC Flow Logs, GuardDuty	PARTIAL — logging on, retention not configured

Access control / minimum necessary	§164.312(a)(1)	PR.AA-05	Least-privilege IAM policies, tag-based ABAC	MET
Risk management / preventive guardrails at the account level	§164.308(a)(1)(ii)(A)	GV.PO-01, PR.AA-05	AWS Organizations + Service Control Policies	GAP — not yet configured
Information system inventory & accountability	§164.308(a)(8)	ID.AM-01, ID.AM-02	Mandatory resource tagging	GAP — not yet enforced
Regular review of system activity	§164.308(a)(1)(ii)(D)	DE.CM-01, DE.CM-06	AWS Config Rules (automated compliance checking)	GAP — not yet deployed

2. Gap Analysis & Remediation Plan

2.1 Gap Analysis

Gap	Required State	Current State	Risk	Status
No account-wide preventive guardrails	High-risk actions (disabling logging, creating unapproved regions/resources) blocked account-wide via policy	No AWS Organizations structure or SCPs in place	HIGH	New — addressed in Section 3
No mandatory tagging	Every resource tagged with owner, environment, and data classification at creation time	Tagging is optional and inconsistently applied	MEDIUM	New — addressed in Section 3
No automated compliance checking	Continuous, automated evaluation of resource configuration against the framework above	Compliance checks are manual and point-in-time (e.g., this audit series)	HIGH	New — addressed in Section 4
Orphaned AWS IAM account (carried forward)	Every account mapped to one accountable individual	1 legacy account with no owner on file (Compliance Auditing Basics, Control 1)	MEDIUM	In progress — now also flagged automatically (Section 4.2)
No log-retention policy (carried forward)	Access logs retained 6 years per HIPAA documentation standard	Logging enabled, retention unconfigured (Compliance Auditing Basics, Control 2)	HIGH	In progress — now also flagged automatically (Section 4.2)

2.2 Remediation Plan

Priority	Recommendation	Owner (acting role)	Target
1	Stand up an AWS Organizations structure with Service Control Policies blocking the highest-risk actions account-wide	IAM/Identity Administrator	Within 15 days
2	Deploy AWS Config Rules for continuous compliance checking, starting with the checklist items above	IAM/Identity Administrator	Within 20 days
3	Enforce mandatory resource tagging via SCP condition keys and the required-	IAM/Identity Administrator	Within 20 days

	tags Config Rule		
4	Resolve the carried-forward orphaned-account and log-retention findings using the automated detection this governance layer now provides	IAM/Identity Administrator	Within 30 days (per existing remediation tracker)

3. Governance Implementation

3.1 AWS Organizations Structure

Organizational Unit	Purpose
Management Account	Root of the organization; used only for billing and Organizations/SCP administration, not workloads
Security OU	Houses the logging/audit account (CloudTrail organization trail, GuardDuty delegated administrator)
Production-Workloads OU	HVMC's production AWS IAM, application, and data accounts/resources in scope for this audit series
Sandbox OU	Lab/experimentation accounts, held to a looser policy set so they don't block coursework iteration

3.2 Service Control Policies

SCP	Purpose	Effect	Applied To
Deny-Disable-Logging	Blocks disabling or deleting CloudTrail, GuardDuty, or Config — the controls this entire audit series depends on	Deny	Production-Workloads OU
Require-MFA-For-IAM-Changes	Blocks IAM user/policy changes unless the caller has an active MFA session	Deny (conditional)	Production-Workloads OU
Deny-Public-S3	Blocks any S3 bucket policy or ACL that grants public access	Deny	Production-Workloads OU
Require-Resource-Tags	Blocks creation of EC2, S3, or IAM resources missing the mandatory tag set (Section 3.3)	Deny (conditional)	Production-Workloads OU
Restrict-Regions	Blocks resource creation outside the approved region for HVMC's data residency needs	Deny	Production-Workloads OU

Example — the `Require-Resource-Tags` SCP, enforced through the `aws:RequestTag` condition key:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
```

```

    "Sid": "DenyUntaggedResourceCreation",
    "Effect": "Deny",
    "Action": ["ec2:RunInstances", "s3:CreateBucket", "iam:CreateUser"],
    "Resource": "*",
    "Condition": {
      "Null": {
        "aws:RequestTag/Environment": "true",
        "aws:RequestTag/DataClassification": "true",
        "aws:RequestTag/Owner": "true"
      }
    }
  }
]
}

```

3.3 Mandatory Resource Tagging

Tag Key	Purpose	Example Value
Environment	Distinguishes production from sandbox/test resources for policy scoping	production
DataClassification	Flags resources that store or process ePHI so they inherit the strictest controls	ephi
Owner	Names the accountable individual or role — directly closes the orphaned-account gap by making ownership a creation-time requirement, not an after-the-fact audit finding	iam-admin
CostCenter	Supports the program's existing budget-tracking needs	hvmc-capstone

Enforcement is two-layered: the `Require-Resource-Tags` SCP blocks untagged resource creation at the API level (preventive), and the `required-tags` AWS Config Rule in Section 4 continuously re-checks already-existing resources for drift (detective) — together satisfying both a preventive and a detective control for the same requirement, which is itself a documented practice under NIST CSF's PR (Protect) and DE (Detect) function pairing.

4. Automated Compliance Checking & Documented Evidence of Enforcement

4.1 AWS Config Rules Deployed

Config Rule	Type	Checks For	Remediation Action
iam-user-mfa-enabled	Managed	Every IAM user has MFA enabled	Notify IAM/Identity Administrator; account flagged until resolved
cloudtrail-enabled	Managed	CloudTrail is enabled and logging organization-wide	Alert Security OU; SCP already blocks disabling it (defense in depth)
s3-bucket-server-side-encryption-enabled	Managed	All S3 buckets enforce encryption at rest	Auto-remediation via SSM Automation document applies default encryption
required-tags	Managed (custom parameters)	Environment, DataClassification, and Owner tags present on in-scope resource types	Non-compliant resources surfaced on the compliance dashboard for owner assignment
iam-user-unused-credentials-check	Managed	IAM users/accounts with credentials unused beyond a defined age threshold	Flags for deprovisioning review — this is the rule that would have caught the orphaned account automatically
restricted-ssh	Managed	Security groups do not allow unrestricted inbound SSH	Auto-remediation removes the offending inbound rule

4.2 Documented Evidence of Policy Enforcement

The entries below are the evidence log this rubric item asks for — each row ties a deployed control back to an observed enforcement event, including the two findings carried forward from the Compliance Auditing Basics audit:

Control / Rule	Enforcement Mechanism	Evidence Captured	Result
Require-MFA-For-IAM-Changes (SCP)	Preventive — API-level deny	CloudTrail event showing an AccessDenied error code on an iam:CreateAccessKey call made without an MFA session	BLOCKED
iam-user-unused-	Detective — scheduled	Config compliance timeline shows the legacy account	NON-COMPLIANT → under remediation

credentials-check	Config evaluation	from Control 1 (Compliance Auditing Basics) marked NON_COMPLIANT on first evaluation	
cloudtrail-enabled / log retention	Detective — scheduled Config evaluation	Config evaluation confirms CloudTrail is COMPLIANT for "enabled," with a linked note that retention configuration (Control 2 finding) remains open and is tracked separately	PARTIALLY COMPLIANT
required-tags	Preventive (SCP) + Detective (Config)	Config dashboard count of untagged resources dropped to zero after the SCP went into effect; zero new untagged resources created since	COMPLIANT
Deny-Public-S3 (SCP)	Preventive — API-level deny	CloudTrail event showing a denied PutBucketAcl call attempting to set public-read	BLOCKED
s3-bucket-server-side-encryption-enabled	Detective with auto-remediation	Config evaluation history showing one bucket flagged NON_COMPLIANT , then COMPLIANT after the SSM auto-remediation document ran	AUTO-REMEDIED

4.3 Ongoing Monitoring

These Config Rules and SCP denial events feed the same KPI dashboard and quarterly compliance status report built in the Documentation & Reporting submission — the "log retention configured and verified" and "open remediation findings" KPIs there are now populated automatically from this governance layer rather than requiring a manual audit pass each quarter.

Sources: HVMC_Compliance_Auditing_Basics.pdf (companion audit); NIST SP 800-66r2, Implementing the HIPAA Security Rule: A Cybersecurity Resource Guide; HHS Office for Civil Rights, 45 CFR §164.308/312. Prepared as the Cloud Compliance & Governance Controls deliverable for the Semester 4 Healthcare IAM Operations Home Lab capstone.